

Vulnerability Assessment Report

Passive Security Assessment of OWASP Juice Shop

FutureIntern Cybersecurity

Task - 1

Prepared By: THIRUKUMARAN S

CIN: FIT/MAY26/CS8388

DOMAIN: Cybersecurity Intern

Date: May 2026

Objective

The objective of this assessment was to perform a passive vulnerability analysis on the OWASP Juice Shop application using ethical and read-only techniques. The assessment focused on security headers, information disclosure, web server exposure, and configuration weaknesses.

Scope & Ethics

- Publicly accessible web pages only
- Passive scanning techniques only
- No exploitation performed
- No brute force attacks
- No denial-of-service testing
- No authentication bypass attempts

Tools Used

Tool	Purpose
Nmap	Port and service analysis
OWASP ZAP	Passive vulnerability scanning
Browser DevTools	Header inspection
Canva	Report design

Methodology

1. Target website selection
2. Nmap reconnaissance scan
3. OWASP ZAP passive scanning
4. Browser header analysis
5. Vulnerability classification
6. Risk assessment and recommendations

Nmap Service and Port Analysis

A passive reconnaissance scan was conducted using Nmap to identify exposed services and server information.

Findings:

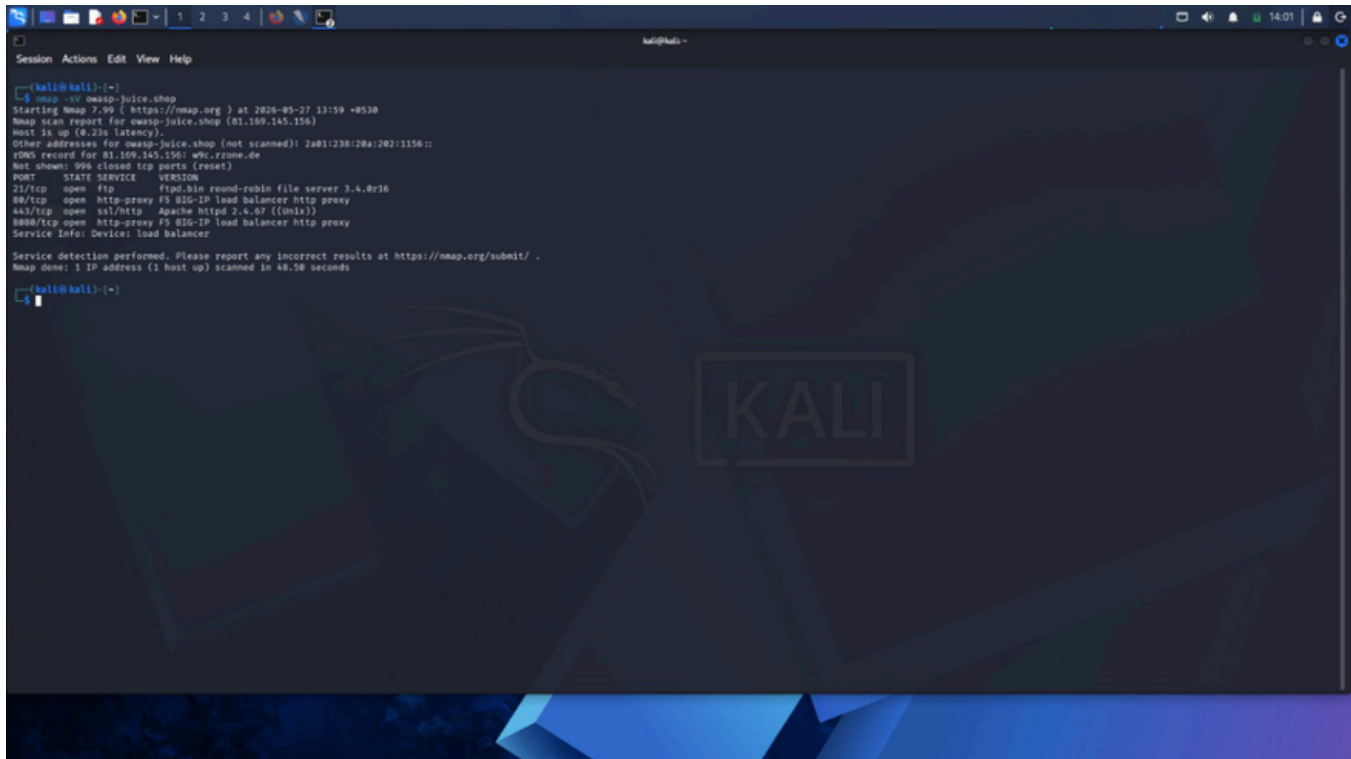
- Port 80 (HTTP)
- Port 443 (HTTPS)
- Port 21 (FTP)
- Apache HTTP Server detected
- BIG-IP Load Balancer detected

Risk Level: Low

Impact: Exposed service and version information may help attackers identify known vulnerabilities.

Recommendation:

- Disable unnecessary services
- Hide server banners
- Restrict public exposure of unnecessary ports



```
kali@kali: ~  
$ nmap -v owasp-juice.shop  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-27 13:59 +0530  
Nmap scan report for owasp-juice.shop (81.109.145.156)  
Host is up (0.23s latency).  
Other addresses for owasp-juice.shop (not scanned): 2a01:238:20a:202::1156::  
rDNS record for 81.109.145.156: wkc.rzone.de  
Not shown: 995 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          ftplib 3.4.0r36  
80/tcp    open  http-proxy   FS 816-IP load balancer http proxy  
443/tcp   open  ssl/http     Apache httpd 2.4.67 ((unix))  
8080/tcp   open  http-proxy   FS 816-IP load balancer http proxy  
Service Info: Device: load balancer  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 48.50 seconds  
kali@kali: ~
```

Content Security Policy (CSP) Header Not Set

The application does not implement a Content Security Policy (CSP) header.

Risk Level: Medium

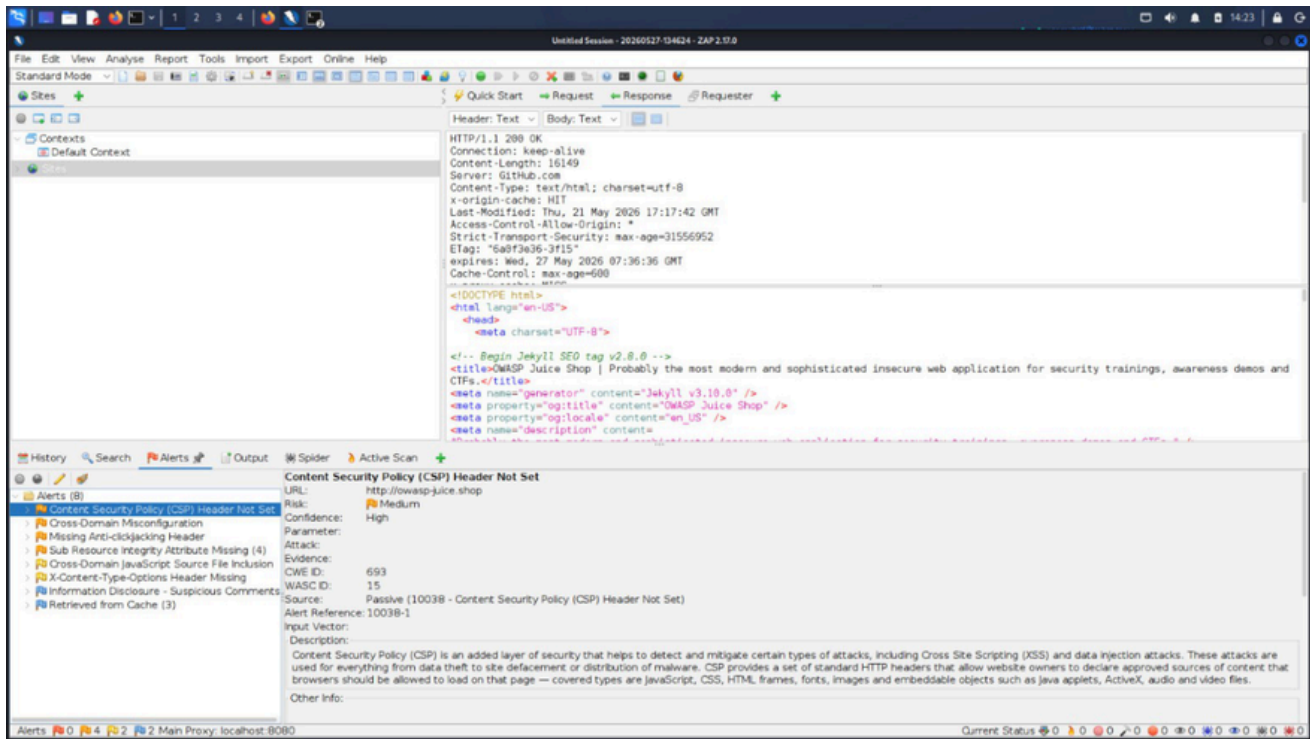
Business Impact:

Attackers may inject malicious JavaScript that could steal session cookies, redirect users, manipulate website content, or compromise user trust.

Evidence: OWASP ZAP passive scan identified the absence of the CSP security header.

Recommendation:

Content-Security-Policy: default-src 'self';



X-Content-Type-Options Header Missing

The anti-MIME-sniffing security header was not configured.

Risk Level: Low

Technical Explanation:

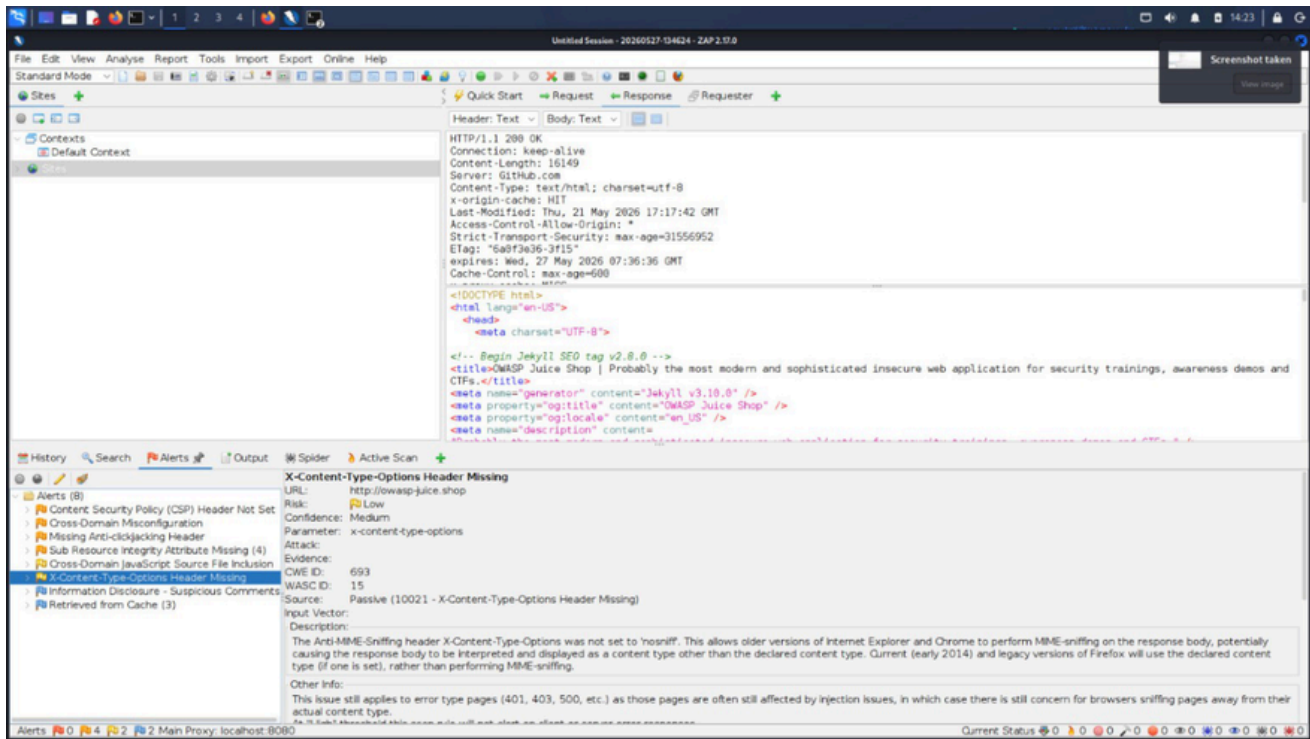
Browsers may incorrectly interpret files as executable content instead of their declared MIME type.

Business Impact:

Attackers may exploit MIME-sniffing behavior to execute malicious scripts or bypass content restrictions.

Recommendation:

X-Content-Type-Options: nosniff



Information Disclosure – Suspicious Comments

HTML comments and internal information were exposed within the application's source code.

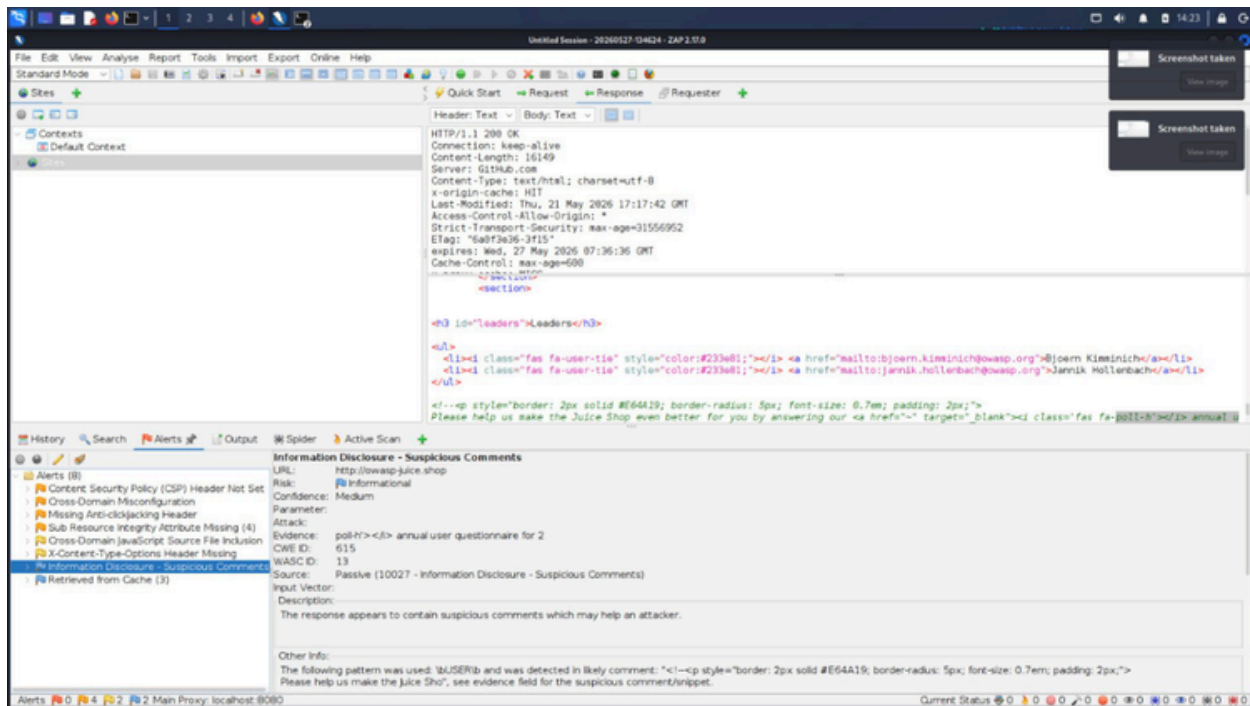
Risk Level: Low

Business Impact:

Information leakage may assist attackers during reconnaissance and increase the effectiveness of targeted attacks.

Recommendation:

- Remove unnecessary comments from production code
- Avoid exposing internal implementation details
- Perform secure code reviews before deployment



Browser Response Header Analysis

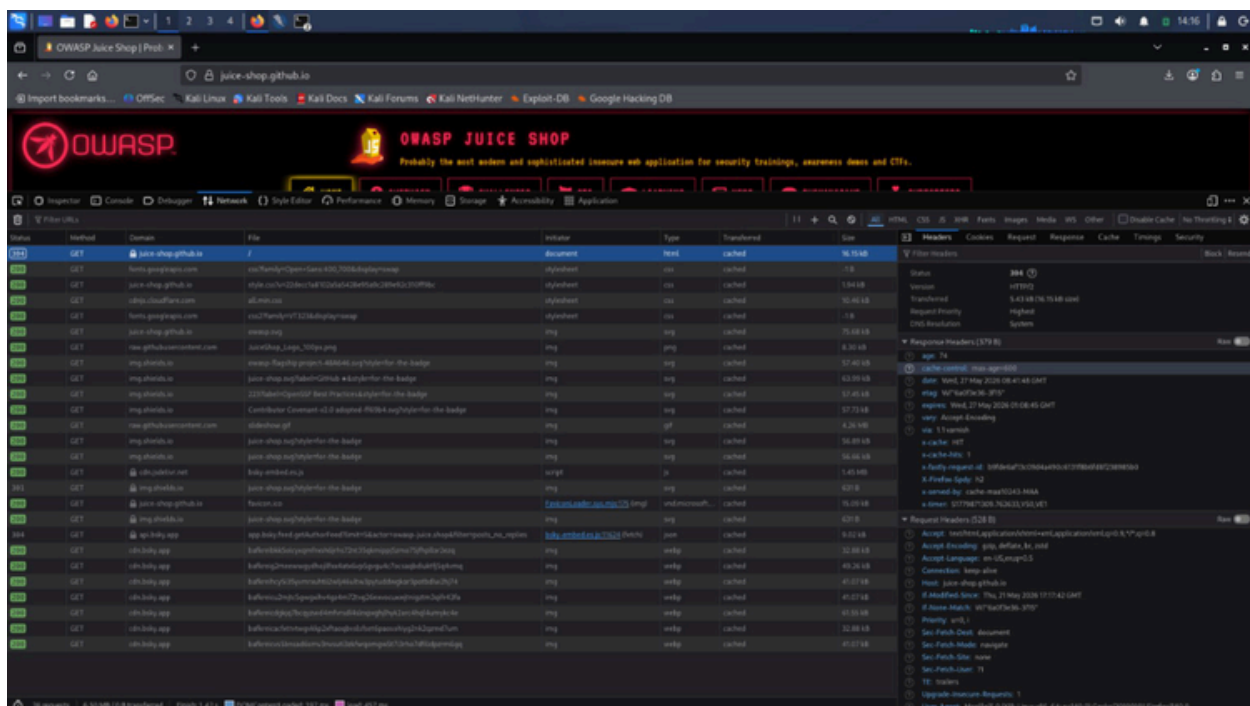
Browser Developer Tools were used to inspect HTTP response headers and analyze security configurations.

Observed:

- Server information disclosure
- Missing security headers
- Cache configuration details

Risk:

Improper header configuration may weaken browser-side security protections.



Risk Summary

Vulnerability	Severity
Missing CSP Header	Medium
Missing X-Content-Type-Options	Low
Information Disclosure	Low
Server Version Disclosure	Low

Recommendations

- Implement missing security headers
- Remove unnecessary information disclosure
- Hide server version details
- Conduct regular vulnerability assessments
- Follow OWASP secure configuration guidelines

Conclusion

The assessment identified multiple low and medium-risk security misconfigurations primarily related to missing security headers and information disclosure.

Although no critical vulnerabilities were identified, implementing the recommended remediation measures would significantly improve the application's security posture.

References

- <https://owasp.org>
- <https://www.zaproxy.org>
- <https://nmap.org>